

APM - Compliance Management Plan - RFFR and ISO/IEC 27001 (ANZ)

Purpose

The purpose of this Compliance Management Plan (the “Plan”) is to establish a structured framework for ensuring ongoing compliance with the Right Fit for Risk (RFFR) accreditation requirements and the ISO/IEC 27001:2022 standard for managing an Information Security Management System (ISMS). This plan outlines the governance and monitoring mechanisms necessary to maintain compliance.

The plan aims to ensure Employment Services RFFR compliance:

- Aligns with the Department of Employment and Workplace Relations’ (DEWR) RFFR accreditation framework, including its core expectations and classification requirements.
- Integrates ISO/IEC 27001 requirements to support continuous improvement and risk-based decision-making in information security.

While also ensuring that all relevant stakeholders understand their roles and responsibilities in maintaining compliance.

Definitions

Term	Definition
Right Fit for Risk (RFFR)	An accreditation framework used by DEWR to assess and manage information security risks for contracted providers.
ISO/IEC 27001: 2022	An international standard for establishing, implementing, maintaining, and continually improving an ISMS.
Information Security Management System (ISMS)	• A systematic approach to managing sensitive company information and information assets to remain secure.
Statement of Applicability (SoA)	The SoA serves as a bridge between the organisation’s risk assessment and its control implementation, ensuring that selected controls are appropriate for the identified risks and compliance obligations. It is a mandatory document required by ISO/IEC 27001 which: • Lists all controls from Annex A of the ISO/IEC 27001 standard. • Indicates whether each control is applicable to the organisation’s ISMS. • Provides justification for inclusion or exclusion of each control. • References how each applicable control is implemented (e.g. via policies, procedures, or technical measures). In addition to the above, the RFFR SoA requires the organisation to use a prescribed template that also includes: • Contractual obligations under DEWR agreements. The Australian Government Information Security Manual (ISM) controls.
Department of Employment and Workplace Relations (DEWR)	The Australian Government department responsible for employment services and related programs.
Information Security Manual (ISM)	A set of guidelines published by the Australian Signals Directorate (ASD) for securing systems.

Essential Eight	A set of eight mitigation strategies recommended by the ACSC to improve cyber resilience.
Annex A	A section of ISO/IEC 27001 that lists security controls grouped into 4 domains: organisational, people, physical, and technological.
Clew	The software solution used by APM for risk management and compliance.

Key stakeholders

The following individuals and groups are considered key stakeholders in the implementation and ongoing management of this Plan. These stakeholders play critical roles in ensuring compliance with both the RFFR framework and the ISO/IEC 27001:2022 standard:

- **Executive Leadership** - Provides strategic direction, allocates resources, and ensures compliance is embedded in organisational priorities.
- **RFFR Program Manager** – Manages the RFFR and ISO/IEC 27001 compliance framework, monitors regulatory changes, and administers the program.
- **System Owners** – System Owners are responsible for ensuring that security risks are assessed and, monitored, the effectiveness of security controls is maintained
- **Control Owners** - Individuals accountable for the design, implementation, operation, and ongoing effectiveness and validation of controls (implementation status, implementation details and applicability).
- **Chief Information Security Officer (CISO)** - Implements and maintains the ISMS and related risk assessments and are accountable for operation of specific security controls.
- **Digital Compliance Team** - Strengthens information security assurance within the Digital team by serving as a central point of coordination and uplift, particularly in relation to RFFR activities.
- **Digital Development and Operations Teams** - Implements and maintains technical controls, manages system configurations, and ensures secure data handling.
- **Business Unit Managers** - Ensures operational compliance within their teams and integrate compliance requirements into daily activities.
- **Legal and Risk Team** - Interprets regulatory obligations, assesses legal risks, and supports contract compliance with DEWR and other related contracts.
- **Human Resources Team** - Manages staff onboarding, training, and disciplinary processes related to compliance and information security.
- **Property Team** - Manages physical security controls and building access, ensuring that facilities are protected against unauthorised entry, environmental hazards, and other physical threats.

Compliance objectives

Strategic goals

The strategic goals of this Plan are designed to ensure we meet our contractual, regulatory, and information security obligations under the RFFR framework and the ISO/IEC 27001 standard. These goals support APM's broader risk management and governance objectives and promote a culture of accountability and continuous improvement.

1. Achieve and maintain RFFR accreditation

Ensure all systems, processes, and personnel meet the requirements set out by DEWR, including information classification, data handling, and reporting obligations.

2. Achieve and sustain ISO/IEC 27001: 2022 certification

Implement and maintain an effective Information Security Management System (ISMS) that aligns with ISO/IEC 27001:2022, including risk-based controls, documented procedures, and continual improvement mechanisms.

3. **Protect sensitive and government-owned information assets**

Safeguard the confidentiality, integrity, and availability of data through robust technical, administrative, and physical controls.

4. **Embed compliance into business operations**

Integrate compliance requirements into day-to-day activities across all relevant departments, ensuring that obligations are met without disrupting service delivery.

5. **Promote a culture of security, risk, and compliance awareness**

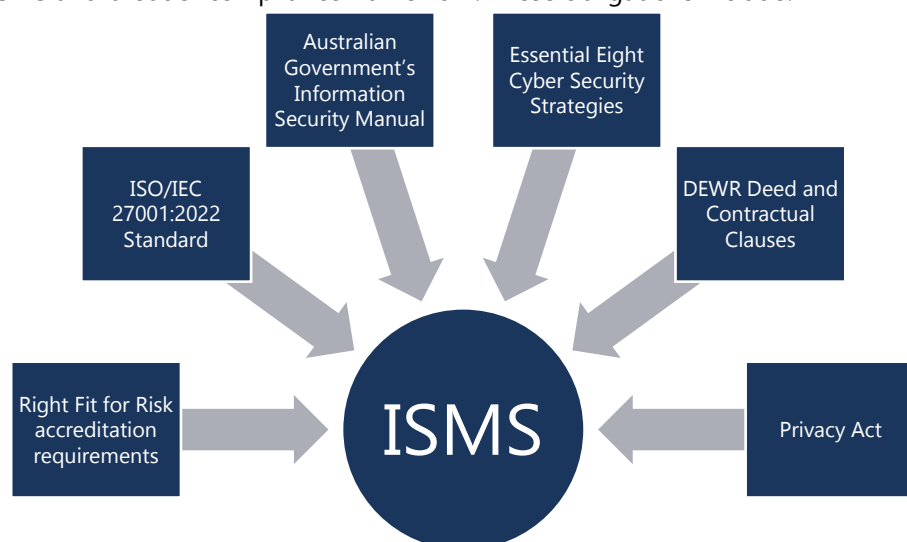
Ensure all staff and contractors understand their responsibilities through targeted training, clear communication, and leadership support.

6. **Monitor, review, and improve compliance performance**

Use audits and control verifications to evaluate the effectiveness of compliance controls and drive continuous improvement.

External obligations

APM is subject to a range of external compliance obligations that influence the design and implementation of our ISMS and broader compliance framework. These obligations include:



Right Fit for Risk accreditation requirements

- Submission of a Statement of Applicability tailored to DEWR expectations.
- Implementation of Core Expectations for personnel, physical, and cyber security.

ISO/IEC 27001:2022 certification

- Adherence to the international standard for establishing, implementing, maintaining, and continually improving an ISMS.
- Fulfilment of Annex A controls and risk-based decision-making processes.

ASD's Information Security Manual (ISM)

- Integration of ISM controls into the ISMS scope and SoA.
- Alignment with government expectations for handling sensitive and classified data.

Essential Eight Cyber Security Strategies

- Implementation of technical controls such as patching, multi-factor authentication, and application hardening.

DEWR Deed and Contractual Clauses

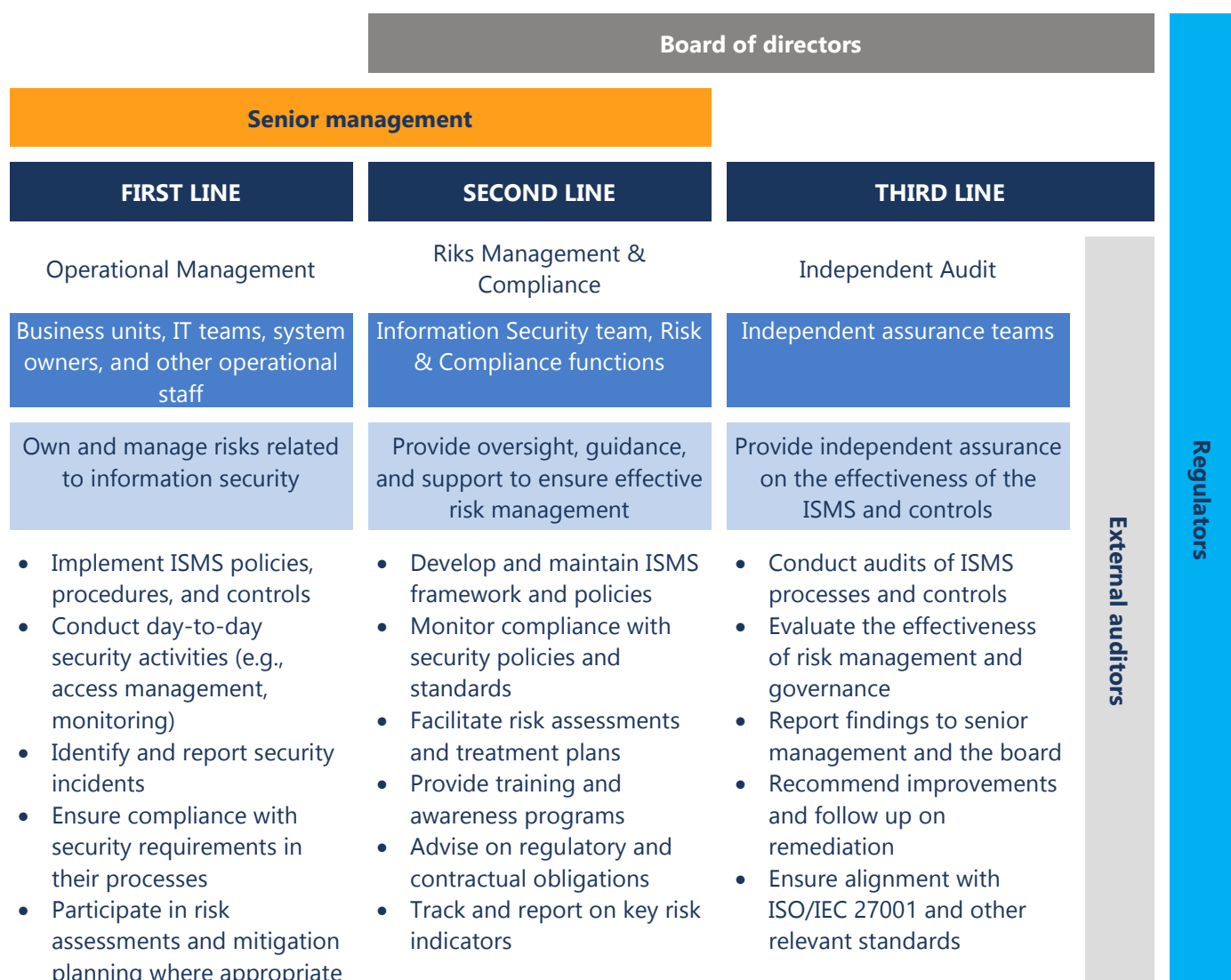
- Fulfilment of specific clauses related to data sovereignty, personnel security, and reporting obligations.

Privacy Act

- Compliance with Australian Privacy Principles (APPs) regarding the collection, use, and disclosure of personal information.

Governance and accountability

The RFFR Program adopts the Three Lines of Defence model to define and clarify roles and responsibilities across the organisation. It supports effective governance by distinguishing between those who own and manage risks, those who oversee risk, and those who provide independent assurance.



Risk Management and Compliance oversight

Compliance status including the management and tracking of risks, controls, actions and continuous improvements are managed in Clew. This ensures that all actions are appropriately documented, tracked, and resolved in a manner that supports continuous improvement and compliance requirements. Within Clew, each action is mapped to relevant

business risks and to existing controls. This linkage supports traceability, enhances oversight, and ensures that actions are aligned with the organisation's risk and control framework.

Oversight is also provided through the following governance structure.

Steering Committee Governing body that owns the program at the highest level	Purpose: Provides strategic oversight and decision-making authority for the program. Suggested Members: Group CFO; Company Secretary; Chief Legal & Risk Officer; CEO Employment Services; ANZ CIO; CISO; Internal Audit Manager; RFFR Program Manager; Compliance Manager Chair: RFFR Program Manager Meeting cadence: Quarterly Responsibilities: • Approves program scope, budget, and major changes. • Monitors overall program progress and risks. • Ensures alignment with organisational strategy. • Resolves escalated issues and risks. • Holds ultimate accountability for program success. • Review and endorses System updates from the System Owners
System Owners Forum A collaborative advisory forum, accountable for control execution and compliance	Purpose: Provides guidance, coordination, and support to the program team, enabling effective operation of controls. Suggested Members: Service Delivery Manager – National Panel of Assessors; GM Customers (Konekt); Head of Employable Me; Head of Cyber Security APAC; Head of Digital Operations; (or delegate); RFFR Program Manager; Compliance Manager Chair: RFFR Program Manager Meeting cadence: Monthly Responsibilities: • Ensure controls are validated, implemented and operating. • Coordinates direction and priorities. • Monitors progress and risks. • Monitor control effectiveness and progress of improvements and corrective actions. • Facilitates stakeholder engagement. • Escalates issues to the Steering Committee. • Review and endorse new controls.
Working Group Task-focused group responsible for progressing specific deliverables or activities within the program, providing subject matter input and operational support	Purpose: To execute specific tasks or deliverables within the program, ensuring controls are implemented as required. Suggested Members: Control Owners, Head of Digital Operations; Compliance Manager; RFFR Program Manager; Head of Product Development; GRC Officer; GM Property; GM Digital Strategy, Investment and Performance; Head of Cyber Security APAC; Risk/legal rep (as required); Human resources representative (as required) Chair: RFFR Program Manager Meeting cadence: Fortnightly Responsibilities: • Ensure controls are implemented and effective. • Execute tasks outlined in this Plan.

- Track remediation activities.
- Review risk and control status and resolve issues.
- Implement specific components of the program or supporting projects.
- Report progress and findings to the System Owners Forum.

Roles and responsibilities

The key responsibilities for compliance oversight can be summarised as follows:

- **Quarterly ISM updates** – The RFFR Program Manager manages the process for assessing ISM updates and ensuring appropriate actions are taken. Control Owners, System Owners, and the Working Group provide support, while the CISO and Compliance team offer technical expertise.
- **Control Assessment and Validation:** – Control Owners maintain operational effectiveness of assigned controls and validate the applicability and implementation details of controls. System Owners have accountability for ensuring controls relevant to the system are selected, implemented and operating effectively.
- **Internal audits** – The Internal Audit Manager coordinates internal audit schedules and templates and supports the execution of the Internal Audit Plan to support ISO 27001 certification, in consultation with the Program Manager, Compliance Manager, CISO, and the System Owners Forum.
- **Management review** – The RFFR Program Manager coordinates the annual ISMS Management Review. Control Owners, System Owners, Risk Owners, the CISO, and the Compliance Manager provide the necessary information for an effective review.
- **External audits** – The RFFR Program Manager and Internal Audit Manager coordinates the external audit schedule. The Internal Audit Manager maintains the relationships with auditors, and together with the RFFR Program Manager, coordinates audit execution. They ensure the SoA is prepared and approved with input from key stakeholders.
- **RFFR accreditation management** – The RFFR Program Manager coordinates completion and approval of the SoA for RFFR accreditation, gathers input from System Owners, Risk and Control Owners, Action Owners, and the CISO, and ensures timely submission to DEWR, including responses to queries.
- **Action management** – Action Owners complete assigned improvement and corrective actions on time, escalate delays, and provide regular updates. Overall accountability for actions rests with the risk and/ or control owner to which the action is linked.
- **Project management** – When control improvements become projects, the Project Manager delivers the project to achieve expected benefits and control implementation, providing updates to the RFFR Working Group and escalating as needed. The RFFR Program Manager coordinates RFFR related project reporting.
- **Compliance oversight** – The RFFR Program Manager ensures the governance framework operates effectively, schedules governance meetings, and coordinates inputs from stakeholders for informed decision-making.

Internal audits and reviews

Internal audits are conducted periodically to assess the adequacy and effectiveness of controls related to RFFR and ISO/IEC 27001. These audits:

- Evaluate alignment with the SoA
- Identify gaps or areas for improvement
- Provide assurance to executive leadership and governance committees

Management review

In accordance with ISO/IEC 27001 requirements, a formal Management Review is conducted at least annually. This review:

09.03.055-1.2	Owner: GM - Quality & Compliance	Publish Date: 26/07/2026	Classification: Internal	Page 6 of 9
---------------	----------------------------------	--------------------------	--------------------------	-------------

- Assesses the effectiveness of the ISMS and compliance framework
- Evaluates changes in external and internal issues relevant to compliance
- Reviews audit results, incident trends, and stakeholder feedback
- Identifies opportunities for improvement and resource need

Attachment 1 - Annual compliance calendar

Milestone/ Event	Description	Frequency	Jan	Feb	Mar	Apr	May	Jun	Jul	Aug	Sep	Oct	Nov	Dec
Right Fit for Risk														
Accreditation maintenance	Submission of updated documentation is required 6 weeks prior to annual anniversary of accreditation.	Annually												
Re-accreditation	Re-accreditation must be completed by the third anniversary of the initial RFFR accreditation. Documents must be submitted 6 weeks before the anniversary date.	Three-yearly												
Remediation actions	Provide evidence of ongoing improvement and timely remediation of identified gaps by specified due dates.	As needed												
ISM updates	Review the quarterly published updates to the ISM. Conduct applicability and risk analysis and action new requirements.	Quarterly (Mar, Jun, Sep, Dec)												
Changes to operating environment	Notify DEWR within 5 days of any changes to our or subcontractors’ circumstances that may affect our risk profile, to enable re-categorisation if required.	As needed												
ISO/IEC 27001														
External surveillance audit	Surveillance audits conducted in Year 1 and Year 2 after initial and re-certification.	Annually												
External re-certification audit	A full audit is required in Year 3 to renew the ISO 27001 certificate for another three-year cycle. Last re-certification was in 2025.	Three-yearly												
Management review	Conduct formal management review meeting. Assess ISMS performance, risks, and improvement opportunities.	Annually												
Governance														
Suggested Frequency														
Control validation	Control owners perform control validation including verifying implementation status, implementation details and applicability	Quarterly												
Internal audit	Conduct internal audit of ISMS controls, including Annex A controls and risk treatment plans. ISM controls, and RFFR core	Annually												

Milestone/ Event	Description	Frequency	Jan	Feb	Mar	Apr	May	Jun	Jul	Aug	Sep	Oct	Nov	Dec
	expectations for personnel, physical and cyber security.													
Working Group meetings	To execute specific tasks or deliverables within the program.	Fortnightly	■	■	■	■	■	■	■	■	■	■	■	■
System Owners Forum meetings	Provides guidance, advice, and support to the program team.	Monthly	■	■	■	■	■	■	■	■	■	■	■	■
Steering Committee meetings	Provides strategic oversight and decision-making authority for the program.	Quarterly			■			■			■			■
Policy & Procedure updates	Review of ISMS and RFFR-related policies, and procedures at least annually but more frequently if needed to reflect changes in the operating environment.	At least annually						■						